Tunneling RDP et SOCKS avec SocksOverRDP:

En pentest on est souvent "limité" a un reseaux windows on ne peux donc pas utiliser SSH pour le pivoting. On va donc utiliser SocksOverRDP un outil qui crée un tunnel SOCKS à travers une connexion RDP Il se compose de deux parties:
SocksOverRDP-Plugin.dll : Le client qui s'exécute sur la machine windows initial que ce soit une machine d'attaque ou un "C2" foothold.
SocksOverRDP-Server.exe Le serveur qui s'exécute sur la machine pivot
Nous allons également utiliser l'outil Proxifier, c'est "le proxychain de Windows", un programme qui force les applications windows à utiliser un serveur proxy. Ici il va diriger le trafic de nos outils à travers le tunnel SOCKS créé par SocksOverRDP.

Sur notre première machine windows compromise (= la machine d'attaque ici) on transfert les fichiers de SocksOverRDP. On enregistre le .dll qui prépare notre machine a créé le tunnel lors de notre prochaine connexion RDP.

```
C:\Machine\pwnd devenu attaquante> regsvr32.exe SocksOverRDP-Plugin.dll
```
Si bug Windef => `Set-MpPreference -DisableRealtimeMonitoring $true`

- **Activer le tunnel:** On se connecte depuis cette "machine attaquante" en utilisant RDP (mstsc.exe). Le plugin s'activera et demarra un écouteur SOCKS localement sur le port 1080.
- **Demarrer le Serveur sur la Pivot:** On transfert et execute SocksOverRDP-Server.exe (avec des priviliges d'administrateur) sur la machine pivot. Cela devrait compléter la configuration du tunnel. Pour confirmer que le proxy SOCKS est en cours d'exécution sur notre machine initiale : ⚠ on a copier-coller sur RDP

```
C:\Machine\pwnd devenu attaquante> netstat -anto | findstr 1080
```

Configurer Proxifier: Sur notre machine initial (foothold) on configure proxyfier pour utiliser le serveur proxy SOCKS5 à 127.0.0.1. sur port 1080. Désormais tout le trafic generé par les applications sur cette machine, comme une nouvelle connexion RDP, sera injecté dans le tunnel vers la machine pivot qui le relaira vers sa destination finale
⚠ à la fastidieuse si on relai tout le trafic d'une machine un petit employé innocent verrai ainsi son trafic relayé.... (Seulement trafic RDP donc ca va)

